

Plantilla de Reporte Ejecutivo (PowerPoint)

Resultados de la Encuesta sobre Pirámide del Dolor y Métricas de Detección

Esta plantilla describe la estructura recomendada de una presentación ejecutiva. Cada “diapositiva” se indica con un encabezado; el contenido puede adaptarse según el público (Consejo, Comité de Riesgos, Dirección de TI, etc.).

Diapositiva 1 – Título

- Título: “De los hashes al dolor real: estado de nuestra detección”
- Subtítulo: “Resultados de la encuesta sobre Pirámide del Dolor y métricas de detección”
- Datos: nombre de la organización, fecha, responsable de la presentación.

Diapositiva 2 – Mensaje clave en una frase

- Texto central (grande):
“Detectamos mucho, pero no siempre donde más duele al adversario.”
- Subtexto:
Una síntesis honesta del diagnóstico (por ejemplo: “Nuestra madurez en TTP es menor que en IoC, lo que limita el impacto real de nuestras inversiones en detección.”)

Diapositiva 3 – Recordatorio: ¿Qué es la Pirámide del Dolor?

- Gráfico simple de la Pirámide (seis niveles).
- Viñetas breves:
- Niveles bajos: hashes, IPs, dominios – fáciles de cambiar.
- Niveles medios: artefactos de red y host – requieren más esfuerzo del adversario.
- Niveles altos: herramientas y TTP – cambiar aquí duele de verdad.
- Comentario: “No todas las alertas valen lo mismo: algunas simplemente persiguen sombras, otras cambian el guion del atacante.”

Diapositiva 4 – Metodología de la encuesta

- Población objetivo (a quién se preguntó).
- Número de respuestas válidas.
- Breve descripción de los bloques de la encuesta.
- Nota sobre la escala de madurez (0–100) y la construcción del Índice Global de Madurez (IGM).

Diapositiva 5 – Índice Global de Madurez (IGM)

- Gráfico de barras con:
- IGM_IoC
- IGM_Artefactos
- IGM_TTP
- IGM_Gobernanza
- Mensaje: “Nuestra fortaleza relativa está en X, nuestra debilidad en Y.”

Diapositiva 6 – Posicionamiento global

- Si se dispone de datos comparativos (sector, país):
- Gráfico de barras comparando la organización con la media del sector/país.
- Ejemplo: “Estamos por encima de la media en gobernanza, pero por debajo en detecciones basadas en comportamiento.”

Diapositiva 7 – Detalle: IoC de bajo nivel

- Resumen visual (p. ej., semáforos) de:
- Calidad de gestión de hashes.
- Gestión de IPs y dominios (caducidad, limpieza).
- Mensaje clave:
“Tenemos una base razonable de IoC, pero no siempre medimos su vida útil ni su impacto real.”

Diapositiva 8 – Detalle: Artefactos de red y host

- Puntos clave:
- Nivel de despliegue de reglas de red y host.
- Existencia de métricas sobre alertas previas a incidentes graves.
- Mensaje:
“Aquí empieza a jugarse la partida: debemos reforzar la calidad y la revisión de estas reglas.”

Diapositiva 9 – Detalle: TTP y MITRE ATT&CK

- Indicadores:
- Uso (o no) de ATT&CK.
- Métricas de cobertura de técnicas.
- Práctica de elevar detecciones de IoC a TTP.
- Mensaje:
“Nuestro uso de ATT&CK es (incipiente / razonable / avanzado), pero todavía hay margen para que las detecciones se alineen mejor con el comportamiento real del adversario.”

Diapositiva 10 – Métricas de tiempo y eficacia

- Gráfico con MTDD y MTTR.
- Si se dispone: desglose según nivel de primera detección (IoC vs TTP).
- Mensaje:
“Cuando detectamos a niveles altos, reducimos significativamente tiempo e impacto. Necesitamos que eso ocurra más a menudo.”

Diapositiva 11 – ROI potencial de la mejora en TTP

- Gráfico (barras o cascada) con:
- Coste actual de incidentes y operación.
- Ahorros estimados tras mejora en TTP (según hoja de ROI).
- Mensaje:
“Invertir en detección de alto nivel no es un capricho técnico: reduce incidentes, esfuerzo de analistas y, en última instancia, coste total.”

Diapositiva 12 – Principales brechas identificadas

- Entre 3 y 5 brechas clave, redactadas en lenguaje no técnico, por ejemplo:
- “Dependencia excesiva de listas de IoC que caducan rápido.”
- “Cobertura insuficiente de técnicas ATT&CK relevantes para nuestro sector.”
- “Escasa medición de la eficacia real de nuestras reglas de detección.”

Diapositiva 13 – Plan de acción propuesto (12-24 meses)

- Tabla simple con columnas:
- Iniciativa
- Responsable
- Plazo
- Indicador de éxito
- Ejemplos:
- “Definir y medir cobertura ATT&CK mínima para sistemas críticos.”
- “Revisión trimestral de reglas con más falsos positivos.”
- “Integrar métricas de Pirámide del Dolor en el cuadro de mando de la dirección.”

Diapositiva 14 – Riesgos de inacción

- 3-4 bullets claros, por ejemplo:
- Aumento de incidentes graves pese a más gasto en seguridad.
- Saturación crónica del SOC por ruido.
- Dificultad para cumplir con obligaciones de NIS2 y similares.
- Mensaje:
“No hacer nada también es una decisión, con su correspondiente ROI negativo.”

Diapositiva 15 – Cierre

- Reiterar el mensaje clave:
“La Pirámide del Dolor no es sólo un dibujo: es una estrategia para invertir mejor nuestro esfuerzo de detección.”
- Llamada a la acción:
- Validación del plan de acción.
- Compromiso de seguimiento periódico.
- Integración de estas métricas en los comités correspondientes.

Sugerencia: adaptar el tono (más técnico o más de negocio) en función del público. El objetivo es que cualquier miembro de la dirección entienda por qué merece la pena subir en la Pirámide, aunque nunca haya oído hablar de TTP.